

Manual 09 - Implementación Controlada del Marco de Ciberseguridad NIST 2.0

CANDIDATO CONTROLADO PARA QA DE PUBLICACION

Revisión de fuente controlada: 321d4fd0e034995ef589a3308af53cab361a9859 | Idioma: es-419 | se mantienen los límites de resultados del CSF y de decisión humana.

Límite de aseguramiento: Este manual operacionaliza resultados de NIST CSF 2.0, pero no crea certificación NIST, no garantiza efectividad de ciberseguridad, no establece cumplimiento legal ni demuestra que un conjunto de controles sea universalmente suficiente. Perfiles, Niveles, excepciones, riesgo residual y decisiones materiales requieren juicio humano responsable.

Rutas de implementación

Manual 09 — Rutas de implementación de NIST CSF 2.0

Borrador controlado asistido por máquina (es-419). La edición en inglés sigue siendo la fuente controlada. Esta localización no constituye aprobación semántica ni terminológica humana y permanece sujeta a la compuerta de revisión humana antes de publicación.

Propósito

Estas rutas traducen los resultados de NIST CSF 2.0 en patrones operativos proporcionales sin tratar el Marco como un catálogo prescriptivo de controles ni como un esquema de certificación. Cada ruta requiere contexto organizacional explícito, estrategia de riesgo, Perfil Objetivo, responsables, evidencia, gestión de excepciones y decisiones humanas.

Ruta Esencial

Úsela cuando la complejidad organizacional y la exposición de ciberseguridad permitan una implementación enfocada.

Patrón operativo mínimo:

- establecer gobierno de ciberseguridad y responsabilidad sobre el riesgo;
- definir servicios críticos de misión/negocio y sus dependencias;
- mantener un Perfil Actual básico y un Perfil Objetivo informado por riesgo;
- identificar activos, datos, servicios, proveedores y dependencias tecnológicas importantes;
- mantener un registro priorizado de riesgos de ciberseguridad;
- implementar identidad/acceso, protección de datos, protección de plataformas, monitoreo, respuesta a incidentes y recuperación de acuerdo con el riesgo;
- definir rutas de escalamiento para incidentes y riesgos materiales;
- conservar evidencia de decisiones, pruebas, incidentes, excepciones y remediación significativas;
- revisar el progreso y los cambios materiales con una frecuencia definida.

La finalización requiere evidencia de que la organización puede explicar sus resultados CSF prioritarios, brechas actuales, acciones responsables, riesgo residual aceptado y siguiente punto de revisión.

Ruta Estructurada

Úsela cuando varias unidades de negocio, obligaciones reguladas, proveedores materiales o entornos tecnológicos más complejos requieran gobierno repetible.

Añade a Esencial:

- Perfiles Actual y Objetivo empresariales formales;
- uso definido de los Niveles de Implementación (Implementation Tiers) de CSF como contexto para características de gobierno del riesgo de ciberseguridad, no como certificados de madurez;
- integración con gestión de riesgo empresarial e informes ejecutivos;
- roles, competencias, demanda de personal y planes de capacitación documentados;
- gobierno sistemático de proveedores y riesgo de cadena de suministro cibernética;

- métricas vinculadas a resultados y decisiones, no solo a conteos de actividad;
- mapeos formales de controles/evidencia mediante referencias informativas autorizadas cuando sean útiles;
- desafío independiente o de segunda línea para decisiones de riesgo material;
- manuales de respuesta y recuperación probados y vinculados con prioridades de negocio;
- reevaluación periódica de Perfiles y planificación de mejoras.

La finalización requiere evidencia trazable en las seis Funciones y un plan de mejora aprobado para las brechas materiales.

Ruta Mejorada

Úsela cuando la importancia sistémica, exposición a amenazas, complejidad regulatoria, servicios críticos o apetito de riesgo de la organización justifiquen una integración y aseguramiento más profundos.

Añade a Estructurada:

- análisis cuantitativo o basado en escenarios cuando aporte valor a la decisión;
- monitoreo continuo o de alta frecuencia de resultados materiales y señales de control;
- cruces y flujos de referencias informativas consumibles por máquina con procedencia y validación;
- análisis avanzado de concentración de proveedores, cuartas partes, resiliencia y riesgo de salida;
- pruebas informadas por amenazas y ejercicios adversariales;
- recopilación automatizada de evidencia con controles de integridad, linaje, acceso y excepciones;
- informes de riesgo para ejecutivos y junta vinculados con objetivos empresariales y apetito de riesgo;
- mapeo entre marcos que preserve la semántica de la fuente y no implique equivalencia donde no exista;
- aseguramiento formal de resultados seleccionados de alto riesgo;
- mejora continua basada en incidentes, casi incidentes, pruebas, hallazgos de auditoría, cambios de negocio e inteligencia de amenazas.

La finalización requiere evidencia de que las prácticas automatizadas o avanzadas permanecen gobernadas por decisiones humanas responsables y que las excepciones o limitaciones de herramientas/modelos son visibles.

Ciclo operativo de seis Funciones

1. GOVERN establece contexto, objetivos, estrategia de riesgo, políticas, roles, supervisión y expectativas de cadena de suministro.
2. IDENTIFY determina qué importa, qué puede salir mal y dónde se necesita mejorar.
3. PROTECT implementa salvaguardas proporcionales al riesgo priorizado.
4. DETECT proporciona conocimiento oportuno de eventos y condiciones adversas relevantes.
5. RESPOND contiene, analiza, comunica y mitiga incidentes de ciberseguridad.
6. RECOVER restaura capacidades e incorpora lecciones en el gobierno y la mejora futura.

El ciclo es iterativo. Cambios materiales, incidentes, pruebas fallidas, cambios de proveedores o supuestos de riesgo modificados devuelven las decisiones afectadas a GOVERN e IDENTIFY.

Gráfico de memoria del Manual 09 1

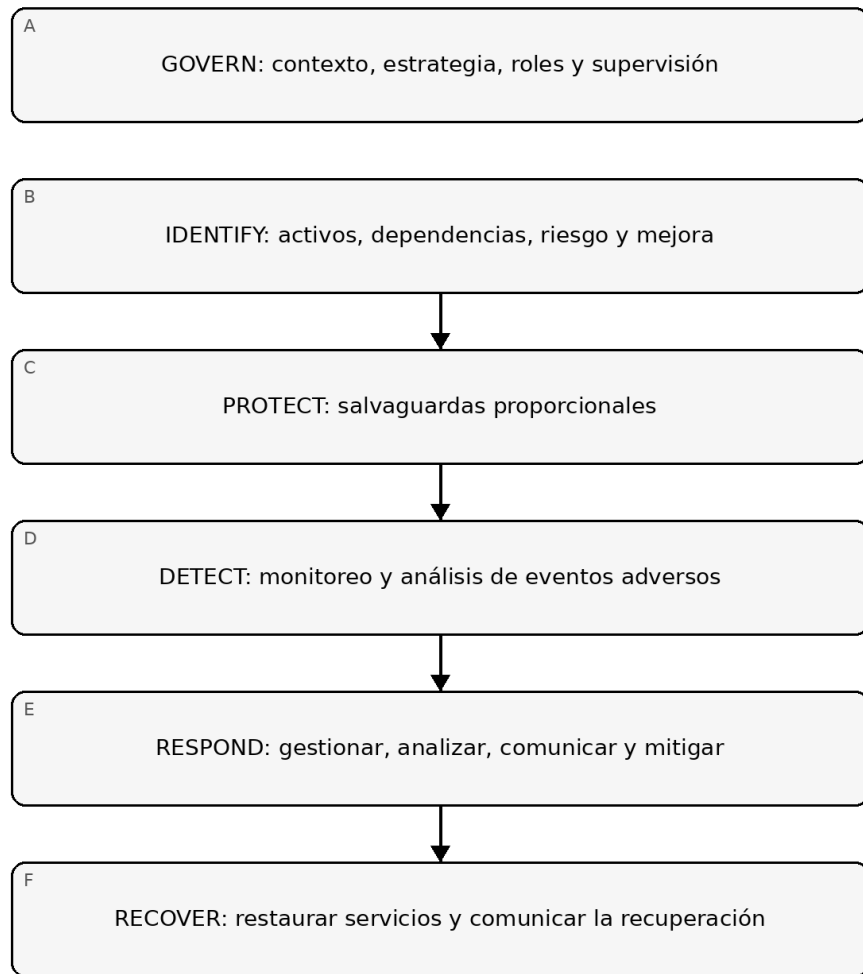


Figura 1. Gráfico de memoria de implementación

Explicación accesible: Las seis Funciones de NIST CSF 2.0 operan como un ciclo conectado y no como listas de verificación aisladas. El gobierno establece el contexto para identificar y proteger; la detección informa la respuesta; y la recuperación devuelve las lecciones, los supuestos modificados y las prioridades de mejora al gobierno.

Ruta de Perfiles y mejora

Gráfico de memoria del Manual 09 2

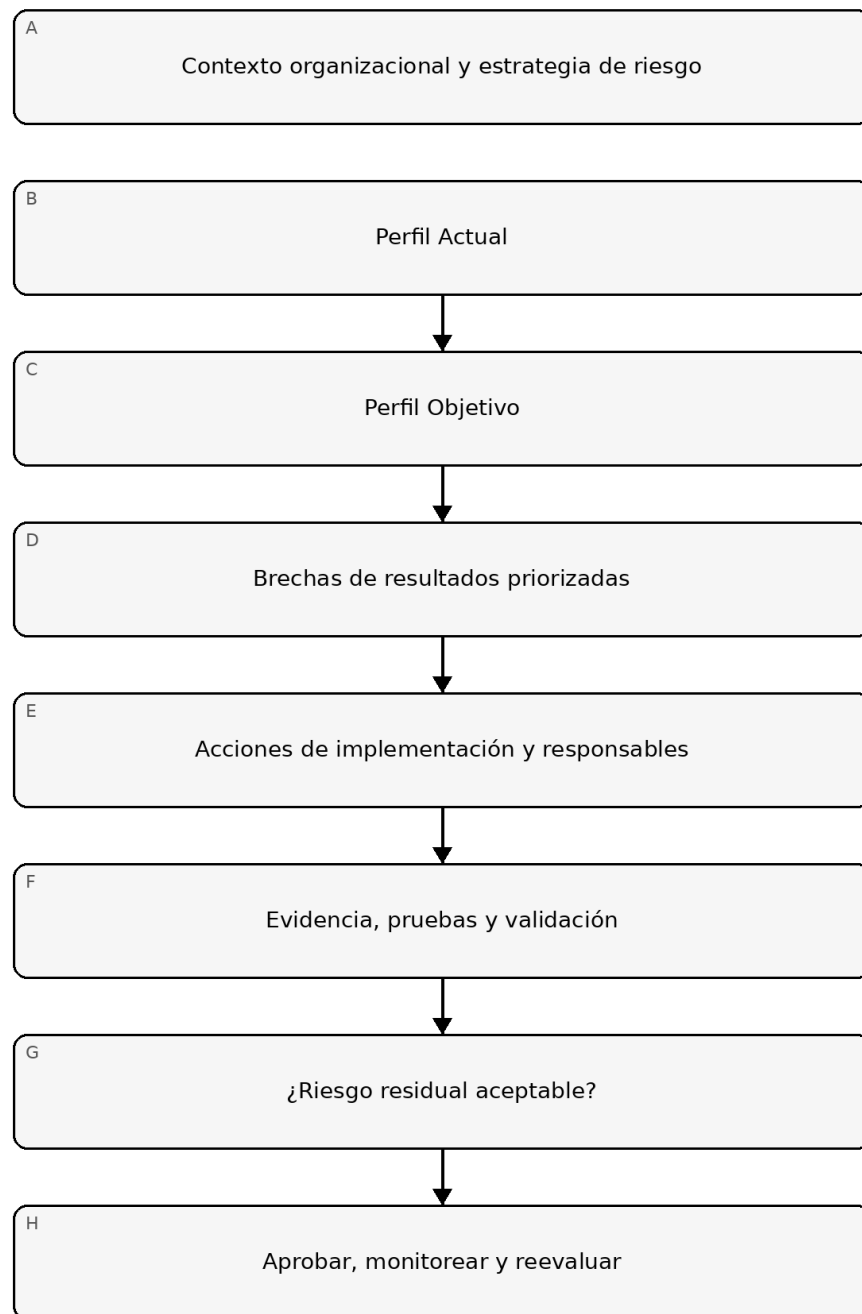


Figura 2. Gráfico de memoria de implementación

Explicación accesible: La implementación de CSF comienza con el contexto organizacional, compara los Perfiles Actual y Objetivo, prioriza brechas de resultados, implementa acciones con responsables y valida evidencia. El riesgo residual inaceptable vuelve al tratamiento; el riesgo aceptado permanece monitoreado y se reevalúa cuando cambian las condiciones.

Enrutamiento de implementación proporcional

Gráfico de memoria del Manual 09 3

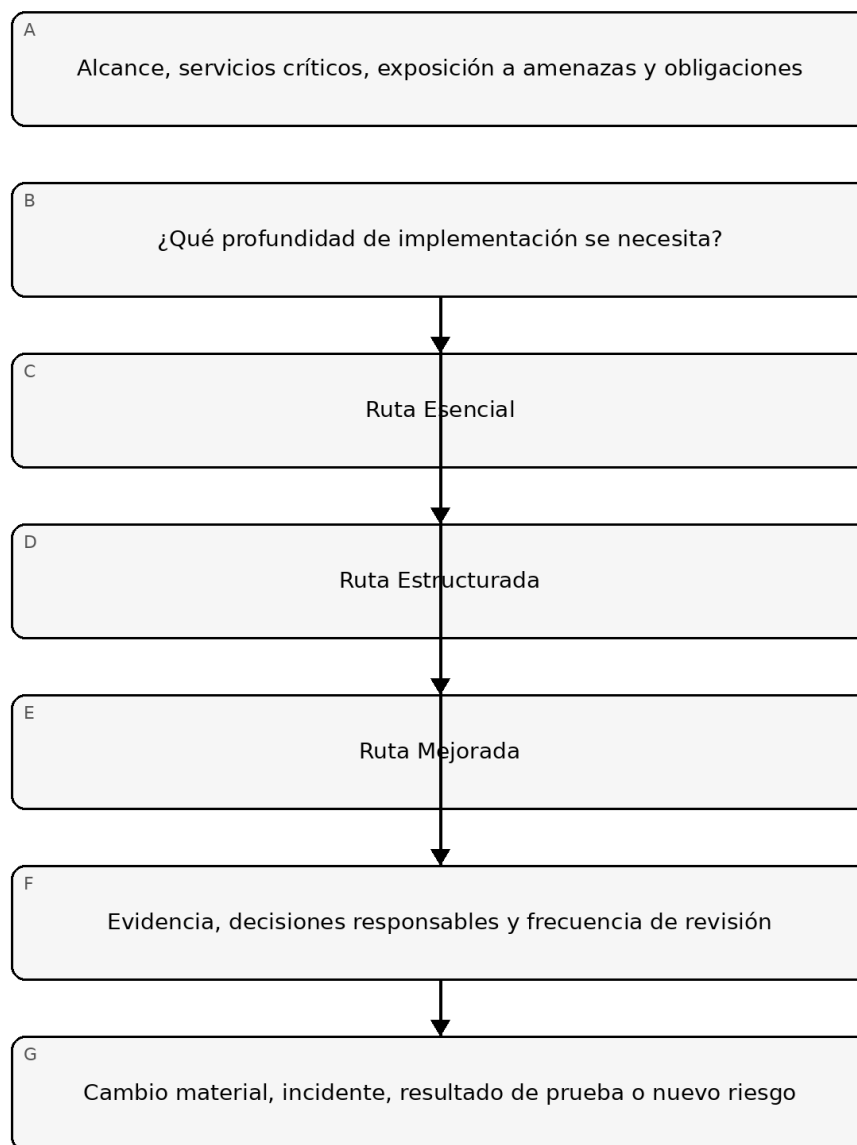


Figura 3. Gráfico de memoria de implementación

Explicación accesible: Las rutas Esencial, Estructurada y Mejorada escalan la profundidad de implementación según el contexto y la exposición organizacional. Todas conservan evidencia, decisiones responsables y reevaluación; cambios materiales o nuevos riesgos pueden requerir una profundidad distinta en lugar de fijar permanentemente a la organización en un nivel.

Ciclo de evidencia y decisión

Para cada resultado CSF material, registre:

- referencia de resultado/subcategoría;
- aplicabilidad organizacional y justificación;
- método de implementación;

- responsable;
- evidencia esperada y observada;
- método de prueba o validación cuando corresponda;
- brecha/hallazgo;
- consecuencia de riesgo;
- tratamiento o excepción;
- fecha objetivo;
- riesgo residual;
- aprobador;
- próxima fecha de revisión.

Una declaración de política, compra de herramienta, respuesta a cuestionario o control mapeado no es suficiente por sí sola para demostrar un resultado.

Condiciones de detención y reversión

La implementación o publicación se detiene cuando el alcance material es desconocido, las brechas de alto riesgo no tienen tratamiento responsable, la evidencia contradice los resultados declarados, las fuentes autorizadas están obsoletas o sin resolver, los mapeos automatizados carecen de procedencia/validación, la revisión humana requerida está incompleta o un cambio material invalida una aprobación anterior.

Declaración de aseguramiento

Manual 09 es guía de implementación. El uso del manual no crea certificación NIST, no garantiza efectividad de ciberseguridad, no establece cumplimiento legal o regulatorio y no demuestra que un conjunto particular de controles sea suficiente para toda organización. Las organizaciones siguen siendo responsables de decisiones de riesgo específicas de su contexto y de revisión humana competente.

Manual controlado de 32 capítulos

Capítulo 01 — Contexto organizacional y dependencia de la misión

Defina la misión, objetivos del negocio, servicios críticos, partes interesadas, contexto legal y contractual, entorno tecnológico y dependencias externas que determinan el riesgo de ciberseguridad. El registro debe aclarar qué resultados son prioritarios y por qué.

La evidencia de implementación debe incluir alcance, servicios críticos, mapas de dependencias, responsables, supuestos y preguntas de alcance no resueltas. Los cambios materiales del negocio o de tecnología deben activar una reevaluación.

Capítulo 02 — Gobierno del riesgo de ciberseguridad

Establezca derechos de decisión sobre el riesgo de ciberseguridad, incluida la responsabilidad ejecutiva, rutas de escalamiento, autoridad delegada, órganos de supervisión y relación con la gestión de riesgos empresariales.

La evidencia debe mostrar quién puede aceptar riesgo, quién desafía las decisiones, cómo los asuntos materiales llegan al liderazgo y cómo la ciberseguridad entra en decisiones de estrategia, inversión, adquisiciones, tercerización y cambio.

Capítulo 03 — Estrategia y apetito de riesgo

Traduzca los objetivos empresariales en supuestos, prioridades, tolerancias, expectativas de respuesta y umbrales de escalamiento de riesgo de ciberseguridad. La estrategia debe ser utilizable en decisiones reales y no limitarse a lenguaje de política.

Documente el apetito de riesgo o criterios equivalentes, opciones de tratamiento, reglas de excepción, frecuencia de revisión y manejo de la incertidumbre.

Capítulo 04 — Roles, responsabilidades y autoridades

Defina responsabilidades de ciberseguridad entre liderazgo, tecnología, seguridad, legal, privacidad, compras, RR. HH., operaciones, gestión de incidentes, resiliencia y proveedores cuando corresponda.

La evidencia debe identificar responsables, operadores, especialistas consultados, autoridad de aprobación, segregación de funciones, suplencias y brechas de capacidad.

Capítulo 05 — Políticas y expectativas de control

Las políticas y estándares deben traducir la estrategia de riesgo en expectativas accionables, permitiendo una implementación específica al contexto. Mantenga propiedad, aprobación, versionado, excepciones, fechas de revisión y registros de comunicación.

Una política no demuestra por sí sola que un resultado se logró. Se requiere evidencia operativa, técnica, de pruebas y de comportamiento cuando sea pertinente.

Capítulo 06 — Supervisión y revisión del desempeño

El liderazgo debe revisar riesgo de ciberseguridad, hallazgos materiales, incidentes, excepciones, problemas de proveedores, preparación para recuperación y progreso de mejora mediante información útil para decidir.

Las métricas deben conectarse con resultados y riesgo. El conteo de actividades no debe presentarse como prueba de reducción efectiva del riesgo.

Capítulo 07 — Gobierno de la cadena de suministro de ciberseguridad

Defina cómo proveedores, prestadores de servicios, software, nube, datos, IA y otras dependencias externas ingresan al gobierno de ciberseguridad. Aplique debida diligencia proporcional, contratación, monitoreo, coordinación de incidentes, análisis de concentración y planificación de salida.

La evidencia de proveedores debe permanecer trazable a servicios críticos y decisiones de riesgo, evitando un ejercicio meramente basado en cuestionarios.

Capítulo 08 — Puerta fail-closed de GOBERNAR

GOBERNAR está incompleto cuando el alcance material no está resuelto, la autoridad de riesgo es ambigua, el liderazgo carece de visibilidad sobre riesgos significativos, las excepciones de alto riesgo no tienen aceptación autorizada o las dependencias de proveedores no están gobernadas proporcionalmente.

La QA automatizada puede validar estructura y campos esperados de evidencia, pero la suficiencia del gobierno requiere juicio humano competente.

Estado de localización: borrador controlado; revisión semántica humana obligatoria antes de aprobación o publicación.

Capítulo 09 — Inventario de activos y servicios

Mantenga visibilidad suficiente de sistemas, aplicaciones, datos, identidades, instalaciones, servicios cloud, tecnología operacional, proveedores y servicios del negocio para soportar decisiones de riesgo. Los inventarios deben identificar responsables, criticidad, dependencias, estado del ciclo de vida y elementos desconocidos.

Los activos no administrados o no identificados deben tratarse como riesgo que requiere investigación.

Capítulo 10 — Evaluación de riesgo de ciberseguridad

Identifique amenazas, vulnerabilidades, exposición, probabilidad o plausibilidad, consecuencias, salvaguardas existentes, incertidumbre y objetivos afectados mediante un método repetible y apropiado.

La evidencia debe diferenciar hechos, supuestos, estimaciones y limitaciones. Las puntuaciones sin razonamiento trazable no son evidencia suficiente.

Capítulo 11 — Priorización del riesgo y mejora

Convierta resultados de evaluaciones, incidentes, pruebas, auditorías, cambios del negocio e inteligencia de amenazas en acciones priorizadas. Registre responsables, fechas objetivo, dependencias, medidas provisionales, riesgo residual y escalamiento.

La mejora debe ser continua y basada en riesgo, no limitada a ciclos periódicos de cumplimiento.

Capítulo 12 — Gestión de identidad y acceso

Gestione identidades, credenciales, autenticación, autorización, acceso privilegiado, cuentas de servicio y ciclo de vida de acceso según riesgo y necesidad del negocio.

La evidencia debe soportar controles de altas/cambios/bajas, gobierno de privilegios, revisiones periódicas, excepciones y retiro oportuno de acceso innecesario.

Capítulo 13 — Concientización y resiliencia de la fuerza laboral

Defina expectativas de conocimiento y comportamiento de ciberseguridad para empleados y terceros relevantes. La capacitación debe reflejar rol, acceso, exposición a amenazas y responsabilidades.

Registre asignación, finalización, atrasos, requisitos específicos por rol, lecciones de incidentes y resultados medibles cuando sea posible.

Capítulo 14 — Seguridad de datos

Proteja los datos según sensibilidad, valor, requisitos legales o contractuales, estado del ciclo de vida y exposición a amenazas. Considere acceso, cifrado u otras protecciones apropiadas, integridad, respaldo, retención, transferencia, disposición y riesgo de fuga.

Las afirmaciones de protección deben estar respaldadas por inventarios, configuraciones, monitoreo, pruebas u otra evidencia pertinente.

Capítulo 15 — Seguridad de plataformas y configuración

Establezca configuración segura basada en riesgo, gestión de vulnerabilidades y parches, defensa contra malware, controles de endpoints/servidores/cloud, integridad de software y gestión del ciclo de vida.

Las excepciones, tecnología sin soporte, controles compensatorios y responsables de remediación deben ser visibles.

Capítulo 16 — Resiliencia de infraestructura y puerta de PROTEGER

Diseñe redes, servicios, instalaciones, dependencias cloud, respaldos, capacidad, segmentación, redundancia y salvaguardas de recuperación según criticidad y riesgo.

PROTEGER está incompleto cuando las salvaguardas críticas son desconocidas, vulnerabilidades materiales carecen de tratamiento responsable, el acceso privilegiado no está controlado, las protecciones de datos no pueden evidenciarse o los supuestos de resiliencia no han sido probados.

Estado de localización: borrador controlado; revisión semántica humana obligatoria antes de aprobación o publicación.

Capítulo 17 — Estrategia de monitoreo continuo

Defina qué condiciones, eventos, activos, identidades, servicios, proveedores y señales de control requieren monitoreo. Establezca fuentes de telemetría, responsables, cobertura, retención, protección, frecuencia de revisión y puntos ciegos conocidos.

La evidencia debe identificar fuentes faltantes o poco confiables; la simple existencia de una herramienta no demuestra visibilidad efectiva.

Capítulo 18 — Detección de eventos adversos

Use señales técnicas y operativas para identificar posibles eventos de ciberseguridad. La lógica de detección debe basarse en riesgo, probarse, ajustarse, versionarse cuando corresponda y conectarse con procesos responsables de triage.

Registre cobertura, falsos positivos, falsos negativos, umbrales de escalamiento y brechas materiales.

Capítulo 19 — Análisis y correlación de eventos

Analice eventos usando contexto relevante como criticidad del activo, identidad, comportamiento, inteligencia de amenazas, vulnerabilidades, impacto y actividad relacionada. Preserve evidencia suficiente para decisiones y revisión posterior.

La correlación automatizada o el análisis apoyado por IA no deben ocultar incertidumbre, inferencias sin soporte, brechas de procedencia ni la necesidad de escalamiento humano.

Capítulo 20 — Declaración y coordinación de incidentes

Defina criterios y autoridad para declarar incidentes, asignar severidad, activar estructuras de respuesta y coordinar seguridad, tecnología, negocio, legal, privacidad, comunicaciones, resiliencia y proveedores.

El registro debe documentar decisiones materiales, responsables, momento, evidencia utilizada y supuestos no resueltos.

Capítulo 21 — Contención y mitigación

Contenga y mitigue incidentes mediante acciones predefinidas y específicas de la situación que consideren consecuencias operativas, de seguridad, legales, probatorias y de recuperación.

Registre responsable, momento, racional, sistemas afectados, validación, necesidad de rollback y riesgo residual.

Capítulo 22 — Comunicaciones de incidentes

Planifique comunicaciones internas y externas, escalamiento, coordinación con partes interesadas, análisis de notificaciones regulatorias o contractuales e interacción con proveedores y clientes según corresponda.

La automatización puede apoyar enrutamiento y redacción, pero no debe tomar decisiones legales de notificación sin revisión humana.

Capítulo 23 — Evidencia de respuesta y lecciones aprendidas

Preserve cronologías, alertas, logs, evidencia forense, decisiones, comunicaciones, acciones de contención, hallazgos, preguntas abiertas y acciones de seguimiento. Realice revisión de lecciones proporcional a la importancia del incidente.

Las lecciones deben alimentar gobierno, evaluación de riesgos, arquitectura, detección, capacitación, supervisión de proveedores y recuperación.

Capítulo 24 — Puerta fail-closed de DETECTAR y RESPONDER

DETECTAR y RESPONDER están incompletos cuando existen puntos ciegos materiales no reconocidos, la autoridad de incidentes es ambigua, alertas críticas no se triagean, la preservación de evidencia es insuficiente o acciones significativas no pueden reconstruirse.

La QA del repositorio puede validar registros esperados y controles estructurales; la efectividad de incidentes y obligaciones legales requieren evaluación humana competente.

Estado de localización: borrador controlado; revisión semántica humana obligatoria antes de aprobación o publicación.

Capítulo 25 — Planificación y priorización de recuperación

Defina prioridades de recuperación a partir de impacto de misión y negocio, dependencias de servicios críticos, riesgo, seguridad, integridad de datos, necesidades contractuales y expectativas de partes interesadas. Establezca roles, comunicaciones, dependencias, criterios de restauración y opciones de contingencia.

Los planes deben identificar supuestos y dependencias que puedan fallar durante un incidente real.

Capítulo 26 — Ejecución y validación de recuperación

Restaura capacidades afectadas usando prioridades controladas y decisiones basadas en evidencia. Valide funcionalidad, seguridad, integridad de datos, acceso, monitoreo y riesgo no resuelto antes de declarar completa la recuperación.

Diferencie restauración temporal, remediación permanente, riesgo residual aceptado y trabajo posterior.

Capítulo 27 — Comunicación y mejora de recuperación

Coordine estado y expectativas de recuperación con liderazgo, dueños de negocio, equipos técnicos, proveedores, clientes y otras partes relevantes. Capture lecciones y aliméntelas al gobierno, riesgo, arquitectura, respuesta y resiliencia.

Las debilidades recurrentes deben convertirse en acciones visibles de mejora.

Capítulo 28 — Perfiles Organizacionales

Use Perfiles Actuales y Objetivo para describir resultados seleccionados del CSF en contexto, identificar brechas, priorizar mejoras y comunicar decisiones de riesgo. Controle alcance, racional, supuestos, responsables, evidencia y fechas de revisión.

Los Perfiles son herramientas de decisión, no certificados ni puntuaciones universales de madurez.

Capítulo 29 — Perfiles de Comunidad y requisitos compartidos

Cuando se utilicen Perfiles sectoriales, comunitarios, de ecosistema o misión, mapéelos transparentemente al contexto organizacional. Registre dónde aplican expectativas compartidas, dónde se requiere adaptación local y cómo se resuelven conflictos o brechas.

El uso de un Perfil externo no elimina la responsabilidad local sobre el riesgo.

Capítulo 30 — Niveles de Implementación e integración empresarial

Use los Tiers del CSF para caracterizar prácticas de gobierno y gestión del riesgo de ciberseguridad en contexto. Deben apoyar decisiones sobre características deseadas e inversión sin tratar un Tier como nivel de certificación ni objetivo automático.

Integre el riesgo de ciberseguridad con gestión de riesgos empresariales y planificación de la fuerza laboral cuando resulte útil.

Capítulo 31 — Referencias informativas, crosswalks y aseguramiento

Use referencias informativas para conectar resultados del CSF con otros estándares, controles, prácticas o requisitos. Mantenga identidad y versión de la fuente, racional del mapeo, dirección, limitaciones, procedencia y validación.

Los mapeos legibles por máquina o asistidos por IA requieren evaluación continua y revisión humana. Un mapeo no demuestra equivalencia ni que un resultado haya sido alcanzado.

El aseguramiento debe distinguir diseño, implementación, operación y calidad de evidencia. Las opiniones formales requieren juicio independiente competente y evidencia suficiente y apropiada.

Capítulo 32 — Liberación, mantenimiento y mejora continua

Manual 09 solo se cierra cuando verificación de fuentes, maestro controlado, revisión técnica/editorial/de seguridad, localización y revisión semántica humana, accesibilidad, QA de publicación, seguridad del repositorio/workflows, procedencia, reconciliación de cambios y Aprobación Humana Final de Liberación estén completas para el mismo candidato exacto.

Los cambios materiales posteriores deben activar análisis de impacto y, cuando corresponda, un nuevo ciclo controlado.

Estado de localización: borrador controlado; revisión semántica humana obligatoria antes de aprobación o publicación.